



SOE 505

SOFTWARE ENGINEERING SECURITY

INTRODUCTION

Software is everywhere from our homes to the streets down to our workplaces. Numerous organizations depend on software to perform basic operations within and outside their organization, but this software can be threatened with security issues that can interfere with its importance. Security issues like bugs, design errors, viruses, and unwanted intruders can disrupt the normal operation of a software product, hence the need to handle these security issues.

Software security refers to the processes and practices involved in developing secure software systems that are resistant to malicious attacks and unintended vulnerabilities. It encompasses all the steps taken to ensure confidentiality, integrity, and availability of software systems throughout the software development life cycle. Software security is critical because software vulnerabilities can lead to cyber-attacks, data breaches, and major disruptions of computer systems. As more critical systems rely on software, the impact of insecure software grows more severe. Software security aims to reduce risks by identifying threats early, designing secure architecture, following best coding practices, and testing rigorously. Implementing software security measures has become essential for organizations to protect their assets and customers in an increasingly interconnected digital world.

Identifying a security issue in a software product is not the best way of treating software security. It is expensive to use this method because when the security issue is detected and treated, there is no guarantee that another security issue will not occur in the future. Hence, the systematic way to handle a security issue is to prevent its occurrence.

These preventive measures include: adopting good design principles, integrating security policy into your software development lifecycle (SDLC), information assurance analysis model, and applying disaster recovery methods. It also involves integrating security mechanisms such as cryptography, authentication and authorization, redundancy, and intrusion detection techniques into the software product. Here, security becomes part of the planning phase, incorporated long before a single line of code is written.

In the next section, we will discuss software security policy creation, maintenance of policies, prevention, avoidance, incidence responses, and domain integration. Subsequently, we will look into security awareness; and forensics legal systems including security services.

5. SOFTWARE ENGINEERING SECURITY POLICY

A software security policy is a set of guidelines detailing the practices and procedures an organization should follow to decrease the risk of vulnerabilities when developing, deploying, and managing a software product. It is a collection of directives and practices designed to govern how software security is maintained within an enterprise. It seeks to safeguard data, prevent breaches, and ensure an uninterrupted user experience. Let's dive deep into the essence of software security, exploring the importance of a robust security policy, and its crucial components.

A security policy is one of the most essential elements of an organization's overall security program. Whether it is a formal or informal policy, a security policy provides the framework for developing and implementing a cohesive set of security controls.

The policy should be tailored to the organization's specific needs and should be reviewed and updated regularly. A software security policy is an integral part of an organization's overall security strategy and can help to protect its software from attack.

As mentioned, the policy should cover all aspects of software security, from development to deployment and maintenance. It should also address how to handle security incidents and vulnerabilities. The policy should specify the acceptable levels of risk for the application and should outline the procedures for managing and responding to security incidents.

5.1 Why is a Software Security Policy Vital for an Organization?

As our lives move increasingly online, data security has become a top priority for organizations of all sizes. A comprehensive software security policy helps to protect an organization's data and systems from unauthorized access and malicious attacks. By defining clear security procedures and controls, an organization can ensure that its data is appropriately protected at all times.

A security policy is vital for an organization because it helps to ensure its data's confidentiality, integrity, and availability. In the event of a security or data breach, an organization can use its security policy to help determine the cause of the breach and take steps to prevent it from happening again.

As mentioned, by having a well-defined security policy in place, an organization can help protect its data and systems from unauthorized access and malicious attacks. A policy can also help companies avoid costly penalties for noncompliance.

5.2 The Elements of a Software Security Policy

A robust software security policy begins with understanding its foundational pillars. Finally, it should clearly define what constitutes a security breach and the consequences for employees who violate the policy. The essential elements of a software security policy include:

- **Objectives:** Start with a clear definition of what the policy covers and its primary goals. This foundation offers a strategic direction to reduce specific threats and vulnerabilities.
- **Scope:** Define what is to be protected (data, software, hardware, etc.).
- **Ownership of Resources:** Designate clear roles related to software security, ensuring clarity in who owns the data processing resources such as data, facilities, and hardware.
- **Responsibility:** Define who is responsible for ensuring that resources are accessed, used, or modified securely.
- **Access Requirements:** Who “needs” access? Requirements may also specify those job functions authorized to determine when an individual requires access to a resource.
- **Standards and Procedures:** Specify the security standards and processes in place. This can encompass everything from encryption standards to authentication mechanisms.
- **Incident Response Plan:** Outline the action plan for any detected security issue. This should cover everything from identification to recovery post-incident.
- **Accountability:** Outline the action(s) to be taken when security is breached.
- **Review and Updates:** Regularly revisit and update the policy, ensuring it adapts to changing threats and organizational shifts.

5.3 How To Create and Implement a Software Security Policy

Building a secure software security policy is not just about listing rules, it is a careful endeavor, demanding collaboration and alignment with broader organizational objectives. After crafting the policy, the real test is in its company-wide deployment. The following steps will guide you through creating and effectively implementing your security policy.

5.3.1 Creating Your Software Security Policy

Creating a robust software security policy requires combining expertise, insights, and strategic planning. To formulate your organization’s software policy, carry out the following actions:

- **Engage Stakeholders:** Foster communication with IT professionals, developers, and business leaders to gather insights.
- **Conduct a Risk Assessment:** Evaluate your current security stance, identifying possible vulnerabilities and potential threats.
- **Draft the Policy:** Use the previously mentioned elements as a template to create a policy suited to your organization’s unique needs.
- **Review and Refine:** Before the final sign-off, review the draft with all stakeholders to ensure the policy is comprehensive and in line with your business goals.

5.3.2 Implementing Your Software Security Policy

Once your software security policy is created, the journey shifts to ensuring its seamless integration across the organization. To implement your software security policy, adhere to the following steps:

- **Educate and Train:** Facilitate training sessions to familiarize your team with the policy details and their respective roles.
- **Integrate into SDLC:** Embed security measures into every step of your software development lifecycle.
- **Employ Software Security Monitoring Tools:** Harness the power of security tools to quickly identify and address vulnerabilities.
- **Regular Audits:** Periodically assess the effectiveness of your policy, making adjustments based on evolving threats and business needs.

5.4 Software Security Standards

Aligning with recognized security standards is priceless when crafting your software security policy. Embracing these standards not only strengthens your security stature but also inspires trust amongst stakeholders and clients. Here are some standards to consider:

- **OWASP Top Ten:** A consensus-driven guideline spotlighting the top web application security threats. An excellent foundation to shield your software products. (See <https://owasp.org/Top10/>)
- **ISO/IEC 27001:** A global benchmark outlining best practices for information security management. (See <https://www.iso.org/standard/27001>)
- **PCI DSS:** Essential for applications handling credit card processes, the Payment Card Industry Data Security Standard provides a fortified transaction environment. (See <https://www.pcisecuritystandards.org/>)
- **NIST Cybersecurity Framework:** Developed by the National Institute of Standards and Technology, it offers guidelines for organizations to adeptly tackle cybersecurity risks. (See <https://www.nist.gov/cyberframework>)
- **SAFECode:** This global nonprofit organization brings business leaders and technical experts together to exchange insights and ideas on creating, improving, and promoting scalable and effective software security programs. (See <https://safecode.org/>)

5.5 Strategies for Preventing Software Security Issues

Several strategies can help prevent software security risks from occurring in the first place. Some best practices for preventing software vulnerabilities include:

- Keeping software up-to-date
- Conducting regular security audits and vulnerability assessments
- Providing security awareness training programs

5.5.1 Keeping Software Up-to-date

Keeping your software development life cycle up-to-date is critical. Software vendors regularly release updates that address security vulnerabilities, so it's important to install these updates as

soon as they become available. These updates may include bug fixes, security patches, and other improvements that can help keep your software security tools safeguarded.

Outdated software can leave your systems vulnerable to attacks that exploit known vulnerabilities. Attackers are well aware of the vulnerabilities in popular software programs, and they often target systems that have not been updated with the latest security patches. Many high-profile data breaches have been caused by attackers exploiting known vulnerabilities in unpatched software.

To ensure that your software development lifecycle is always up-to-date, you can enable automatic updates for your operating system and other software programs. You should also regularly check for updates manually and install them as soon as they become available.

5.5.2 Conducting Regular Security Audits and Vulnerability Assessments

Regular security audits and vulnerability assessments can help identify potential security risks before being exploited. These assessments can help you identify vulnerabilities in your software, network, and systems, allowing you to take steps to address them before they can be exploited by attackers.

Security audits typically involve a comprehensive review of your systems and software development process processes to identify potential security issues. This may include reviewing access controls, identifying vulnerabilities in software and hardware security, and assessing the effectiveness of your security policies and procedures.

Vulnerability assessments are typically more focused and involve identifying specific vulnerabilities in your systems and software. This may involve running vulnerability scans on your network, testing your web applications for security holes, and reviewing your systems for known vulnerabilities.

5.5.3 Providing Security Awareness Training Programs

Finally, providing employee training and awareness programs can help prevent software security issues by educating not only cyber security teams but all employees about the risks and best practices for avoiding them. Training programs help employees learn how to access secure data, recognize phishing scams, avoid downloading malware, and follow best practices for password security, among other things.

Employees may carelessly download malware, fall for phishing scams, or use weak passwords that can be easily guessed or cracked. By providing training and awareness programs, regular reminders, and updates to employees to keep them informed about new security threats; you can help them understand the risks and best practices for avoiding these security threats.

5.6 Preventive Maintenance

Preventive maintenance takes care of your security system so that you catch any problems before they occur. It is about fixing things before they break. Instead of waiting for things to go wrong, preventative maintenance focuses on extending the operational life of the software product. By

performing inspections at regular intervals and making minor adjustments as necessary, you can ensure that your software product is in good working condition.

The main goal of a preventive maintenance plan is to detect potential problems early on and take proactive steps to avoid them. This shows you are not waiting for a system to fail. It provides the following benefits to users and organizations:

- Enhanced customer satisfaction
- Reduced operational costs
- Reduced downtime
- Improved performance
- Improved reliability
- Improved productivity
- Extends asset life
- Reduced maintenance
- Guard organization's reputation

5.7 Types of Preventive Maintenance

There are four major types of preventive maintenance and they are all organized and scheduled differently to suit different business operation purposes.

- **Usage-based preventive maintenance:** This takes into account the average daily usage or exposure to environmental conditions of an asset and uses it to forecast a due date for a future inspection or maintenance task.
- **Calendar/time-based preventive maintenance:** Calendar/time-based preventive maintenance occurs at a scheduled time, based on a calendar interval. The maintenance action is triggered when the due date approaches and necessary work orders have been created.
- **Predictive maintenance:** Predictive maintenance is designed to schedule corrective maintenance actions before a failure occurs. The team needs to first determine the condition of the software to estimate when maintenance should be performed. Then maintenance tasks are scheduled to prevent unexpected software failures.
- **Prescriptive maintenance:** Prescriptive maintenance does not just show that failure is about to happen and when, but also why it is happening. This type of maintenance helps analyze and determine different options and potential outcomes, to mitigate any risk to the operation.

5.8 Incident Response

An incident represents a change in security posture potentially in breach of law, policy, or unacceptable act that concerns information assets, such as software, networks, computers, or smartphones, which may or may not be materially reportable.

Then as the name suggests, Incident Response (IR) is how an organization handles a data breach or cyberattack. It consists of actions taken immediately following a security compromise, attack, or breach. It is an effort to quickly identify an attack, minimize its effects, contain damage, and remediate the cause to reduce the risk of future incidents. In addition to containing the attack, responders must also preserve all relevant evidence for later examination. This requires a team of experienced professionals who understand how to respond to the incident while carefully preserving evidence.

As the frequency and types of data breaches increase, the lack of an incident response plan can increase costs and further damage your information security effectiveness. This makes incident response a critical activity for any security organization.

Implementing a software security incident response plan can help you effectively address a cyber event, reduce disruptions to your business operations, and ensure compliance with regulations.

5.8.1 Incident Response Plan

An incident response (IRP) plan is a set of documented procedures detailing the steps that should be taken in each phase of incident response. It should include guidelines for roles and responsibilities, communication plans, and standardized response protocols. It outlines the actionable steps required to prepare for, respond to, and recover from a cyberattack.

5.8.2 The Importance of Incident Response

When your organization responds to an incident quickly, it can:

- Reduce losses
- Restore processes and services
- Reduce the scope or effects
- Alleviate exploited vulnerabilities

5.8.3 Types of Security Incidents

- **Unauthorized Attempts:** This occurs when an individual or group attempts to gain unauthorized access to an organization's systems or data. Examples include hacking attempts, brute force attacks, and social engineering.
- **Privilege Escalation Attack:** This occurs when an attacker can gain access to a system with limited privileges and then uses that access to gain higher-level privileges. This can be done by exploiting vulnerabilities in the system or using stolen credentials.
- **Insider Threat:** This occurs when a current or former employee, contractor, or other insider uses their access to an organization's systems or data for malicious purposes. Examples include stealing sensitive information or sabotaging systems.
- **Phishing Attack:** This occurs when an attacker sends an email or message that appears to be from a legitimate source but is a trap to steal sensitive information or spread malware.
- **Malware Attack:** This occurs when an attacker uses malware, such as a virus or Trojan horse, to gain access to an organization's systems or data or perform other malicious

activities. Different types of malware can perform different activities. For example, ransomware can prevent access to data until a ransom has been paid.

- **Denial-of-Service (DoS) Attack:** This occurs when an attacker floods a system or network with traffic, causing it to become unavailable to legitimate users.
- **Man-in-the-Middle (MitM) Attack:** This occurs when an attacker intercepts and alters communications between two parties. The attacker can steal sensitive information or spread malware this way.
- **Data Leaks:** This is almost always the fault of poor infrastructure rather than malicious activities such as leaving databases unsecured or without proper security updates, human errors such as employees sending files to incorrect email addresses, third-party vulnerabilities, server errors, etc.
- **Advanced Persistent Threat (APT):** This is a sophisticated and targeted attack designed to gain access to an organization's systems or data, often to steal sensitive information or maintain a long-term presence.

5.8.4 Incident Response Frameworks

Two of the most widely used frameworks for incident response are SANS and NIST.

- **NIST (4-step process):** According to the National Institute of Standards and Technology (NIST), incident response has four steps:
 - Preparation and prevention
 - Detection and analysis
 - Containment, eradication, and recovery
 - Post-incident activity
- **SANS (6-phase process):** According to the SANS Institute, incident response should have six steps:
 - Preparation
 - Identification
 - Containment
 - Eradication
 - Recovery
 - Lessons learned

5.8.5 SANS Incident Response Plan

- **Preparation:** Review and codify an organizational security policy, perform a risk assessment, identify sensitive assets, define the critical security incidents the team should focus on, and build a Computer Security Incident Response Team (CSIRT).
- **Identification:** Monitor the security policy, detect deviations from normal operations, and see if they represent actual security incidents. When an incident is discovered, collect additional evidence, establish its type and severity, and document everything.
- **Containment:** Perform short-term containment, for example by isolating the network segment that is under attack. Then focus on long-term containment, which involves

temporary fixes to allow the software to be used in production while rebuilding clean systems.

- **Eradication:** Remove malware from all affected systems, identify the root cause of the attack, and take action to prevent similar attacks in the future.
- **Recovery:** bring affected production systems back online carefully, to prevent additional attacks. Test, verify, and monitor affected systems to ensure they are back to normal activity.
- **Lessons learned:** Perform a retrospective of the incident not later than two weeks from the end of the incident. Prepare complete documentation of the incident, investigate the incident further, understand what was done to contain it, and whether anything in the incident response process could be improved.

6. SECURITY DOMAINS

Security domains are a fundamental concept in information security, referring to areas within a system where security policies are consistently enforced. Each domain is defined by its security requirements, controls, and boundaries. Understanding security domains is crucial for designing, implementing, and maintaining secure systems.

Security domains are essential for managing and protecting an organization's information systems. By clearly defining and enforcing security policies within each domain, organizations can better protect their resources, minimize the impact of security breaches, and ensure compliance with regulatory requirements. Understanding and effectively managing security domains is a critical component of a robust information security strategy.

6.1 Importance of Security Domains

- **Isolation:** Limits the impact of security breaches by containing threats within a domain.
- **Policy Enforcement:** Ensures consistent application of security policies.
- **Access Control:** Manages and restricts access to resources within a domain.
- **Compliance:** Helps in meeting regulatory and organizational security requirements.

6.2 Components of Security Domains

- **Security Policy:** A set of rules defining how data and resources are protected.
- **Entities:** Users, devices, applications, and data within the domain.
- **Security Controls:** Mechanisms and tools used to enforce the security policy.
- **Trust Levels:** This means the different levels of trust that can be assigned to various entities within or across domains.

6.3 Types of Security Domains

- **Physical Security Domains:** Defined by physical boundaries such as buildings or secure rooms.
- **Logical Security Domains:** Defined by logical boundaries such as network segments or virtual environments.
- **Organizational Security Domains:** Defined by organizational boundaries such as departments or business units.

6.4 Examples of Security Domains

- **Internal Networks:** Corporate intranets, isolated from the internet.
- **External Networks:** Public-facing network segments, such as web servers.
- **Development Environments:** Isolated domains for software development and testing.
- **Production Environments:** Domains where live data and applications are running.

6.5 Managing Security Domains

- **Boundary Definition:** Clearly defining the boundaries of each domain.
- **Policy Development:** Creating detailed security policies for each domain.
- **Access Control:** Implementing strict access controls to enforce policies.

- **Monitoring and Auditing:** Continuously monitoring and auditing domain activities.
- **Incident Response:** Preparing for and responding to security incidents within each domain.

6.6 Challenges in Security Domains

- **Complexity:** Managing multiple domains with varying policies and controls can be complex.
- **Inter-Domain Communication:** Ensuring secure communication between domains.
- **Scalability:** Scaling security policies and controls as the organization grows.
- **Compliance:** Keeping up with regulatory requirements across different domains.

6.7 Security Domains Best Practices

- **Segmentation:** Divide networks into smaller, manageable segments.
- **Least Privilege:** Grant the minimum level of access necessary for each user or device.
- **Regular Audits:** Conduct regular security audits to identify and address vulnerabilities.
- **Consistent Policies:** Ensure security policies are consistently applied across all domains.
- **Training and Awareness:** Educate employees about security policies and practices.

6.8 Security Awareness and Possible Domains

Security awareness is a critical aspect of any organization's security strategy. It involves educating and informing employees, stakeholders, and users about the potential security threats and the best practices to prevent security breaches. The primary goal is to cultivate a culture of security within the organization to protect its assets and data.

6.8.1 Importance of Security Awareness

- **Risk Mitigation:** Reduces the likelihood of human errors that could lead to security breaches.
- **Compliance:** Ensures adherence to regulatory and legal requirements.
- **Incident Response:** Prepares employees to respond effectively to security incidents.
- **Cultural Shift:** Promotes a security-first mindset across the organization.

6.8.2 Basic Components of Security Awareness

- **Training Programs:** Having regular training sessions on security policies, threat identification, and response strategies.
- **Communication:** Having continuous communication through emails, posters, newsletters, and alerts.
- **Simulated Attacks:** Conducting phishing simulations and other tests to assess and improve employee readiness.
- **Policy Enforcement:** Enforced security policies that employees must follow.
- **Feedback Mechanism:** Providing a platform for employees to report security concerns and incidents.

6.8.3 Domains of Security Awareness: Security awareness spans various domains, each addressing different aspects of organizational security:

- **Information Security**
 - Protecting data from unauthorized access, disclosure, alteration, and destruction.
 - Implementing data encryption, access controls, and regular audits.
- **Physical Security**
 - Securing physical assets like servers, data centers, and office premises.
 - Using access badges, surveillance cameras, and secure locks.
- **Network Security**
 - Safeguarding the organization's network infrastructure from intrusions and attacks.
 - Deploying firewalls, intrusion detection/prevention systems, and secure VPNs.
- **Application Security**
 - Ensuring that software applications are free from vulnerabilities.
 - Conducting regular code reviews, security testing, and employing secure coding practices.
- **Endpoint Security**
 - Protecting devices like computers, smartphones, and tablets that connect to the network.
 - Using antivirus software, device management solutions, and enforcing security policies.
- **User Awareness**
 - Educating users about phishing, social engineering, and other common threats.
 - Promoting the use of strong passwords and multi-factor authentication.
- **Incident Response**
 - Preparing for and effectively managing security incidents.
 - Having a well-defined incident response plan and regular drills.
- **Compliance and Legal**
 - Adhering to laws, regulations, and industry standards related to security and privacy.
 - Regularly reviewing compliance requirements and updating policies accordingly.

6.8.4 Developing an Effective Security Awareness Program

- **Assessment:** Evaluate the current level of security awareness in the organization.
- **Customization:** Tailor the program to address specific threats and organizational needs.
- **Engagement:** Use interactive and engaging methods to deliver training.
- **Measurement:** Continuously measure the effectiveness of the program through assessments and feedback.
- **Improvement:** Regularly update the program to address new threats and incorporate best practices.

7. FORENSICS LEGAL SYSTEMS

Forensic, according to Oxford Dictionary, is a technique used in connection with the detection of crime. The forensics legal system involves the application of scientific principles and methods to the investigation of crimes and legal issues. It encompasses the collection, preservation, and analysis of evidence, and the legal processes that govern its admissibility in court.

The forensics legal system is a crucial intersection of science and law, providing objective and reliable evidence for the resolution of criminal cases and legal disputes. By adhering to rigorous standards and continually advancing forensic technologies, the justice system can more effectively ensure the integrity and fairness of legal proceedings.

7.1 Importance of Forensic Science in the Legal System

- **Evidence Collection and Analysis:** It provides reliable and objective evidence for criminal investigations and legal proceedings.
- **Crime Scene Investigation:** It helps in reconstructing the crime scene and understanding the sequence of events.
- **Legal Proceedings:** It assists in the prosecution and defense by presenting scientific evidence in court.
- **Identification:** It helps in identifying suspects and victims through DNA analysis, fingerprinting, and other methods.

7.2 Types of Forensic Evidence

There are various types of forensic evidence for criminal investigations, which include the following:

- **Physical Evidence:** Tangible objects like weapons, clothing, and fingerprints.
- **Biological Evidence:** Bodily fluids, hair, and tissues used for DNA analysis.
- **Chemical Evidence:** Substances like drugs, poisons, and explosives.
- **Digital Evidence:** Information stored or transmitted in digital form, including emails, texts, and files.
- **Trace Evidence:** Small materials transferred between objects or persons, such as fibers or gunshot residue.

7.3 Forensic Disciplines

Forensics science can be applied in many areas which include:

- **DNA Analysis:** Examines genetic material to identify individuals.
- **Toxicology:** Studies the effects of chemicals on the human body, including drugs and poisons.
- **Ballistics:** Analyzes firearms, bullets, and the trajectory of projectiles.

- **Fingerprint Analysis:** Identifies individuals based on unique fingerprint patterns.
- **Digital Forensics:** Investigates electronic devices to uncover digital evidence.
- **Forensic Pathology:** Determines cause of death through autopsies.
- **Forensic Anthropology:** Studies human remains to determine identity and cause of death.

In this course, we will concentrate on the field of digital forensics.

7.4 Digital Forensics

Digital forensics is the process by which experts collect, examine, and analyze data from compromised computer systems and storage devices to answer questions such as “*How did the attack happen?*” and “*How do we prevent it from happening again?*”. This is done carefully, following professional best practices, to ensure that the evidence could be admissible in a court of law if necessary.

Analysts focus on recovering, investigating, and examining material found on digital devices. The end goal of digital forensics is to gather and preserve evidence to aid in prosecuting cybercrime, should the culprits behind an attack face criminal charges.

Generally, an organization engages in digital forensics to:

- Confirm the occurrence of a cyberattack
- Understand the full impact of a cyber incident
- Identify the cause behind a cyberattack
- Collect evidence proving a cyberattack occurrence

Like any forensic investigation, speed is critical, especially if an attack is ongoing. Acting fast can help stop in-progress security incidents and reduce overall damage to the victim organization.

Computers, networks, and devices continuously produce data that could potentially be crucial to an investigation, even while sitting idle. Over time, the risk that this data is deleted, overwritten, edited, or otherwise maliciously altered increases. Many forensic artifacts depend highly on the state of a computer in the immediate aftermath of an incident. Forensic investigators must move quickly to ensure they capture all this information before it is lost or unrecoverable.

7.5 Digital Forensics and Incident Response

Digital Forensics and Incident Response (DFIR) is a practice used by incident response teams to detect, investigate, and respond to cyber threats facing an organization. As the name suggests, DFIR consists of two related components:

- Digital forensics involves collecting, preserving, and analyzing forensic evidence
- Incident response involves containing, stopping, and preventing a cyberattack

DFIR fuses traditional incident response (IR) activities with digital forensics techniques. While traditional IR usually carries some investigative elements, DFIR takes it to another level by emphasizing digital forensics.

With DFIR, businesses can return to business after a cyberattack and at the same time improve their resiliency against future attacks. Given just how expensive and damaging a single attack can be, it is more important than ever to know how to respond to a cybersecurity incident if you are targeted.

The first priority when a cyber-attack occurs is to recover from the incident. But recovery is not enough. To fully eradicate the threat and prevent it from recurring the organization needs to understand what happened. These are the questions DFIR attempts to answer, questions such as:

- Who are the attackers?
- How did they gain access?
- What are the exact steps they took to put the system at risk?
- What was the actual damage they caused?
- What data was lost?
- What can be done to close those security gaps?

Digital forensic information collected by DFIR experts is frequently used to file lawsuits against identified attackers. It is also commonly used by law enforcement and can be used as evidence in court proceedings against cybercriminals.

7.6 The Digital Forensics Process

The digital forensic process is the accepted method investigators follow to gather and preserve digital evidence, with the express intent of maintaining a chain of custody. It consists of three key steps:

- **Identification:** The first step in digital forensics is identifying evidence and understanding where and how it is stored. This often requires deep technical expertise and analysis of digital media. In this step, investigators create an exact duplicate of the media in question, usually using a hard drive duplicator or specialized software tools. The original media is secured to prevent any tampering.
- **Preservation:** Once data has been identified, the next step is isolating, securing, and preserving all data until the investigation is over. This includes any regulatory or litigatory inquiries.
- **Analysis:** Forensic specialists then analyze the duplicated files or technology, logging all the evidence they discover that supports or contradicts a hypothesis. Analysis is conducted to reconstruct events and actions in an incident, helping them reach conclusions about what happened and how hackers compromised systems.
- **Documentation:** At this stage, the team uses the relevant evidence discovered to recreate the incident or crime for a thorough investigation.

- **Reporting:** Once a digital forensics investigation is completed, the findings and conclusions analysts uncovered are delivered in a report that non-technical personnel can understand. These reports are passed on to those who commissioned the investigation and usually wind up in the hands of law enforcement.

Again, once digital forensics is complete, DFIR teams can begin the incident response process.

7.7 The Incident Response Process

Once digital forensics is complete, DFIR teams can begin the incident response process.

- **Scoping:** The first goal is to assess an incident's severity, scope, and breadth and identify all indicators of compromise (IoCs).
- **Investigation:** The search and investigation process can begin once the scope is determined. Advanced systems and threat intelligence can detect threats, collect evidence, and provide in-depth information.
- **Securing:** Even with individual threats addressed, organizations still need to identify security gaps and conduct ongoing monitoring of cyber health. This stage often involves containing and eradicating active threats identified during the investigation and closing any identified security gaps.
- **Support and Reporting:** Ideally, each security incident ends with a detailed plan for ongoing support and customized reporting. A DFIR service provider may also examine the organization and provide expert advice for the next steps.
- **Transformation:** Finally, DFIR teams identify gaps, advise on effectively strengthening areas of weakness, and mitigate vulnerabilities to improve the organization's security posture.

7.8 Types of Digital Forensics Data

During the acquisition phase of the digital forensic process, analysts look for a variety of forensic data to help them in their investigation:

- **Disk Images:** A disk image refers to a copy made of a digital storage device. Disk images are bit-for-bit copies of devices, usually of hard disks or hard drives. Sometimes images may be taken on a USB drive or other storage medium.
- **Memory Images:** A computer's RAM can be recorded by special software, similar to a disk image. Memory images are vital because some threat actors are undetectable on disk.
- **Application Data:** If a disk or memory image is unavailable or irrelevant, investigators sometimes turn to application data (such as host logs, network device logs, and software-specific logs) instead.

7.9 Digital Evidence

Think of every police case story you have heard, read, or seen; investigators catch the suspects by uncovering and documenting evidence that helps them recreate the exact circumstances surrounding a crime. Digital evidence is no different: it comprises significant information transmitted or stored on a digital device during a crime. Generally, digital evidence should meet these five key criteria:

- It is admissible in court
- It is authentic
- It is complete
- It is reliable
- It is believable

DFIR investigators will gather this information and store it safely to prevent contamination to ensure it remains admissible in court.

7.10 How To Store Digital Evidence

In theory, gathering digital evidence should be as simple as pulling out a hard drive infected with ransomware. In practice, it is not quite so simple.

Some types of digital evidence are deemed volatile or non-persistent because the data is only accessible when that device is plugged in or connected to power. Non-volatile or persistent digital evidence, meanwhile, is stored permanently in memory. This may include read-only memory, data in flash memory, or even data on a CD-ROM or other disc.

In many cases, investigators cannot and will not power down affected technology to preserve digital evidence.

Because of these challenges, DFIR investigators typically start by duplicating a hard drive via drive imaging, a process that creates a bit-to-bit perfect duplicate of a drive affected by an attack. As a rule, investigators will operate exclusively on this duplicate drive when investigating. This allows them to explore and test hypotheses on the drive without impacting the actual evidence.

The imaging process also generates cryptographic hash values, which are used to verify the authenticity of a drive image. Wherever possible, evidence gathered will be stored in a secure location where it can be preserved and accessed for reference later, with added physical security to ensure no item can be compromised.

7.11 Rules of Evidence

The rule of evidence in software engineering is referred to as the principles and practices that ensure that digital evidence is collected, preserved, and presented in a manner that is admissible and credible in a court of law. This concept is crucial in digital forensics and cybersecurity, where

the integrity and authenticity of evidence can determine the outcome of legal proceedings. Key aspects include:

- **Authentication:** Ensuring that the digital evidence is genuine and can be reliably attributed to its source.
- **Data Integrity:** Maintaining the original state of the evidence from the point of collection through analysis and presentation, typically ensured by using checksums or cryptographic hashes.
- **Chain of Custody:** Documenting the handling of evidence at every step to prove that it has not been altered or tampered with.
- **Relevance:** Demonstrating that the evidence directly pertains to the case and has a meaningful connection to the matter being adjudicated.
- **Competency:** Ensuring that the methods and tools used to collect and analyze the evidence are scientifically valid and that the individuals handling the evidence are qualified and trained.
- **Admissibility:** Ensuring that the evidence complies with legal standards and rules so that it can be used in court.

These principles guide how security incidents are investigated and how digital evidence is managed to support legal actions against cybercriminals or to defend against accusations.

7.12 Search and Seizure Laws and Rights

Search and seizure, when referring to criminal law, is how law enforcement searches an individual's property (home, vehicle, etc.) to gather evidence to prove a suspect guilty in court. When an investigation is being conducted, searches regularly occur to obtain evidence to be used against someone. However, such searches must be done in accordance with the nation's constitution, which protects citizens against unreasonable search and seizures.

In the context of digital forensics, search and seizure is referred to as the process of investigating and collecting digital evidence from computer systems, networks, or other electronic devices. This process is guided by legal and procedural standards to ensure that evidence is obtained lawfully and can be used effectively in legal contexts. The key aspects of search and seizure include:

- **Legal Authorization:** Search and seizure of digital evidence typically requires legal authorization, such as a warrant or court order, to ensure that the process complies with laws and protects privacy rights. This authorization outlines what can be searched and seized.
- **Scope and Limitations:** The scope must be clearly defined to prevent overreach. Investigators must limit their activities to the areas specified in the legal authorization to avoid violating privacy or collecting irrelevant data.
- **Preservation of Evidence:** Ensuring that digital evidence is preserved in its original state is crucial. This involves using techniques like creating forensic copies (images) of storage media to prevent alteration or loss of data during the search.

- **Chain of Custody:** Maintaining a detailed record of who collected, handled, and examined the evidence to ensure its integrity and admissibility. Proper documentation helps establish that the evidence has not been tampered with or compromised.
- **Forensic Tools and Techniques:** Employing specialized forensic tools and techniques to search for, identify, and collect evidence from digital devices. These tools must be reliable and validated to ensure accurate results.
- **Data Handling:** Carefully managing and securing the data collected during the search and seizure process. This includes protecting data from unauthorized access and ensuring it is stored securely.
- **Compliance with Procedures:** Adhering to established procedures and best practices for digital evidence collection and handling to ensure that the process is legally sound and that the evidence is admissible in court.
- **Ethical Considerations:** Acting ethically and professionally during the search and seizure process, respecting privacy rights, and avoiding unnecessary disruption to individuals or organizations.

Search and seizure in the digital realm is a complex process that requires careful planning, legal compliance, and technical expertise to ensure that evidence is gathered effectively and lawfully.

7.13 Security Services

Security services are the set of measures and protocols implemented to protect software systems and data from unauthorized access, attacks, and breaches. These services ensure the confidentiality, integrity, and availability of the system and its data. It ensures that software systems operate securely and are resilient against threats. These security services include:

- **Authentication:** Verifying the identity of users and systems to ensure that only authorized individuals can access the system.
- **Authorization:** Determining and enforcing what authenticated users are allowed to do within the system.
- **Encryption:** Protecting data by converting it into a code to prevent unauthorized access.
- **Data Integrity:** Ensuring that data is accurate and has not been tampered with.
- **Non-repudiation:** Providing proof of the origin and delivery of data to prevent denial of involvement in communication or transactions.
- **Intrusion Detection and Prevention:** Monitoring systems for suspicious activity and taking action to prevent potential security breaches.
- **Access Control:** Restricting access to resources based on user roles and permissions.
- **Security Auditing and Logging:** Keeping records of system activities to detect and analyze security breaches.
- **Firewall and Network Security:** Protecting the network from unauthorized access and attacks.

7.14 Challenges in Forensics Legal System

The forensic legal system faces several challenges, including:

- **Technological Advancements:** Rapid advancements in technology outpace the legal system's ability to adapt, leading to challenges in dealing with new types of digital evidence and cybercrimes.
- **Data Volume and Complexity:** The sheer volume and complexity of digital data can overwhelm forensic investigators, making it difficult to collect, analyze, and present evidence effectively.
- **Chain of Custody:** Maintaining a clear and unbroken chain of custody for digital evidence is crucial but challenging, as digital data can be easily altered or corrupted.
- **Lack of Standardization:** There is a lack of standardized procedures and protocols in digital forensics, leading to inconsistencies in evidence handling and analysis.
- **Privacy and Ethical Concerns:** Balancing the need for thorough investigations with privacy rights and ethical considerations is a significant challenge.
- **Resource Constraints:** Many forensic labs and law enforcement agencies face resource constraints, including limited funding, outdated equipment, and insufficient personnel.
- **Legal Knowledge:** Lawyers, judges, and juries often lack the technical expertise to fully understand and evaluate digital evidence, potentially impacting the outcome of cases.
- **Jurisdictional Issues:** Cybercrimes often cross national and international boundaries, complicating jurisdictional matters and the enforcement of laws.
- **Evolving Criminal Techniques:** Cybercriminals continuously develop new methods to evade detection, requiring forensic experts to constantly update their skills and tools.
- **Admissibility of Evidence:** Ensuring that digital evidence is admissible in court can be challenging due to questions about its authenticity, integrity, and relevance.
- **Expertise and Training:** Maintaining a high level of expertise and ongoing training for forensic professionals to handle complex cases accurately.

ACRONYMS

IEC: International Electrotechnical Commission
ISO: International Organization for Standardization
NIST: National Institute of Standards and Technology
OWASP: Open Web Application Security Project
PCI DSS: Payment Card Industry Data Security Standard
SDLC: Software Development Lifecycle
SANS: SysAdmin, Audit, Network and Security
IoCs: Indicators of Compromise
IR: Incident Response
DFIR: Digital Forensics and Incident Response
VPN: Virtual Private Network